LEDGERLY / SECURITY SELF-ASSESSMENT

FinTechathon 2026 | International Track | Topic E: SME Finance Copilot | 20 October 2026

System boundary

Local Python finance copilot using synthetic transaction data. The baseline planner is deterministic. Financing offers, approvals, lender interactions and cash movement are simulated; no live lender, payments network or language-model service is connected.

Implemented security controls

AREA	IMPLEMENTED CONTROL
Tool permissions	Registered tools are restricted by READ, PREPARE, ACT_LOW and ACT_MONEY tiers.
Purpose checks	Credit assessment and lender-pack preparation require separate purpose grants.
Action approval	Application and disbursement are separate sandbox actions with mandatory affirmative approvals.
Safe matching	A recommendation must cover the full request and pass eligibility and coded repayment capacity checks.
Data handling	Lender packs omit raw transaction rows and direct identifiers; common identifiers in memo text are screened.
Audit trail	Local JSONL entries form a SHA-256 hash chain, verified before append.
Sandbox safeguards	Simulated loan principal is capped at NGN 5 million; duplicate funding is blocked within one process.
Local web wrapper	Optional UI binds to 127.0.0.1:8765; browser-origin checks apply when Origin is supplied.

Priority risks and required actions

PRIORITY	CURRENT LIMITATION	REQUIRED BEFORE LIVE USE
Critical	Owner identity and approvals are not authenticated or cryptographically bound to transaction terms.	Authenticated sessions; signed/payload-bound approvals; expiry, revocation and replay controls.
Critical	No live banking or lender adapter has been tested.	Credential isolation, limits, verification, transaction reconciliation and external integration review.
High	Local files and logs lack production encryption, access rules and retention.	Encryption, access management, retention and secure deletion.
High	Affordability, forecast and passport are unvalidated heuristics.	Holdout testing, financial review, stressed schedules and post-deployment monitoring.
High	Masking and hostile-input screening may miss sensitive content or indirect instructions.	Allowlisted disclosure fields, strict validation and adversarial testing.
High	Local hash chain can be rewritten by the operator; replay protection is process-local.	External audit checkpoints and durable idempotency records.
High	No real protected-group outcome testing has been conducted.	Governed fairness assessment with appropriate consent and sampling.
Medium	Optional model callback and web wrapper are not production hardened.	Plan-schema validation, authentication, browser and security testing.

Verification

Run: python3 -m unittest discover -s tests -v | python3 run_demo.py

64 passing tests: 24 original cases and 40 safety regressions. Checks include financing refusal, separate approval gates, invalid inputs, sandbox replay and audit integrity. The browser interface has not undergone full end-to-end testing.

Assessment status

Team self-assessment only; not an independent audit or compliance certification. This release is suitable for synthetic offline demonstration, not for real customer records or financial transactions.